

AFRICA-ZT-EDU: A Policy-Centric Zero-Trust and Privacy-Preserving Architecture for Cross-Border Digital Education in Africa

Abdessamad Bourkibate 

Department of Computer Science, University of the People, Pasadena, CA, USA.
Faculty of Legal, Economic and Social Sciences, Cadi Ayyad University, Marrakech, Morocco.
Share In, Casablanca, Morocco.
ORCID: 0009-0000-6186-8071.



Industry affiliation: Share In, Casablanca, Morocco.

Abstract—Cross-border digital education can widen access to courses, assessments, and portable academic credentials, but it also distributes identity, academic, payment, proctoring, and learning-analytics data across institutions, cloud providers, and jurisdictions. This paper presents AFRICA-ZT-EDU, a policy-centric reference architecture that combines zero-trust access control with purpose limitation, jurisdiction-aware transfer decisions, data minimization, verifiable credentials, privacy-enhanced analytics, and signed decision receipts. The artifact is developed using design-science research, a structured synthesis of official standards and policy instruments, and a combined STRIDE/LINDDUN-inspired threat model. Fourteen engineering requirements are derived and mapped to testable mechanisms. Evaluation has three complementary parts. First, a transparent 36-objective analytical rubric yields 34/36 (94.4%) explicit control coverage for the proposed design versus 15/36 (41.7%) for a deliberately defined perimeter-centric reference profile. Second, a reproducible synthetic experiment evaluates 3,000,000 authorization requests across 24 synthetic institutions and 12 abstract jurisdiction profiles. Across 30 independent seeds, AFRICA-ZT-EDU records a false-permit rate of 0.0095% (95% CI: 0.0082–0.0108), blocks 99.750% (95% CI: 99.716–99.785) of otherwise-authorized prohibited transfers, and reduces mean disclosed fields from 12.702 to 4.920 (61.26%). Third, a single-host microbenchmark measures a median of 0.1210 ms and a 95th percentile of 0.1384 ms for a composite authorization path containing Ed25519 verification, a conservative 200-rule scan, AES-256-GCM encryption of a 10 KiB payload, and receipt hashing. An illustrative differential-privacy experiment yields a median cohort-rate error of 0.550 percentage points at $\epsilon = 1$. These results validate policy expressiveness and local computational feasibility under declared synthetic assumptions; they are not production breach estimates, legal determinations, or compliance certifications.

Index Terms—zero trust architecture, digital education, Africa, cross-border data flows, privacy engineering, verifiable credentials, differential privacy, federated analytics, attribute-based access control, policy as code

I. INTRODUCTION

Digital education systems increasingly operate as federations rather than self-contained learning-management systems. A

learner may authenticate through an external identity provider, study in a cloud-hosted learning environment, submit an assessment to a separate proctoring service, pay through a regional processor, receive a digital credential from an issuing institution, and later present selected claims to an employer or another university. Each step can cross technical, institutional, and national boundaries. The African Union (AU) Digital Education Strategy and Implementation Plan 2023–2028 explicitly seeks wider adoption of digital technologies for teaching, learning, research, assessment, and administration, while also emphasizing digital skills and infrastructure capacity [1]. The AU Data Policy Framework similarly calls for harmonized governance and a trustworthy shared data environment that protects rights and supports intra-African digital activity [2].

The enabling environment remains uneven. International Telecommunication Union estimates for 2025 place Internet use at 73.6% globally, 35.7% in Africa, and 23.4% in low-income economies [3]. The UN Trade and Development Global Cyberlaw Tracker reports that 76% of African countries have enacted data-protection and privacy legislation, but the existence of a law does not imply identical transfer rules, institutional capacity, terminology, or enforcement practice [4]. The AU Convention on Cyber Security and Personal Data Protection, commonly called the Malabo Convention, entered into force in June 2023; the status list dated 8 July 2024 records 21 signatures and 16 ratifications or accessions among 55 AU member states [5], [6]. These indicators describe a landscape in which educational interoperability is desirable, but indiscriminate centralization is difficult to justify.

Security architecture must therefore address more than the classic perimeter. NIST defines zero trust as removing implicit trust based solely on network location or ownership and requiring explicit authentication and authorization for access to resources [7]. NIST SP 800-207A extends this logic to cloud-native and multi-location systems through application and service identities, gateways, and granular policies [8]. However, zero trust does not by itself answer privacy questions such as whether a transfer is necessary, which fields are proportionate to a declared educational purpose, how learner rights are implemented, or how analytics should limit re-identification and inference. Privacy engineering and educational ethics must therefore be co-designed with access control [9]–[12].

TABLE I
CONTEXT INDICATORS USED TO MOTIVATE THE ARCHITECTURE (NOT EVALUATION OUTCOMES)

Indicator	Value	Source / date	Architectural interpretation and caution
Individuals using the Internet – world	73.6%	ITU DataHub, 2025 [3]	Global benchmark used only to contextualize network-dependent service design.
Individuals using the Internet – Africa	35.7%	ITU DataHub, 2025 [3]	Supports low-bandwidth, asynchronous, and bounded-offline requirements; it does not describe every country or institution.
Individuals using the Internet – low-income economies	23.4%	ITU DataHub, 2025 [3]	Reinforces graceful degradation and non-smartphone alternatives.
African economies with data-protection/privacy legislation	76.0%	UNCTAD tracker, accessed 2026 [4]	Indicates broad legislative adoption, not harmonized rules, equivalent enforcement, or automatic transfer permission.
Malabo Convention signatures	21/55 (38.2%)	AU status list dated 8 July 2024 [6]	Treaty participation is one governance signal among several; the denominator and date must remain explicit.
Malabo Convention ratifications/accessions	16/55 (29.1%)	AU status list dated 8 July 2024 [6]	The architecture therefore uses reviewed jurisdiction profiles rather than a single assumed continental rule.

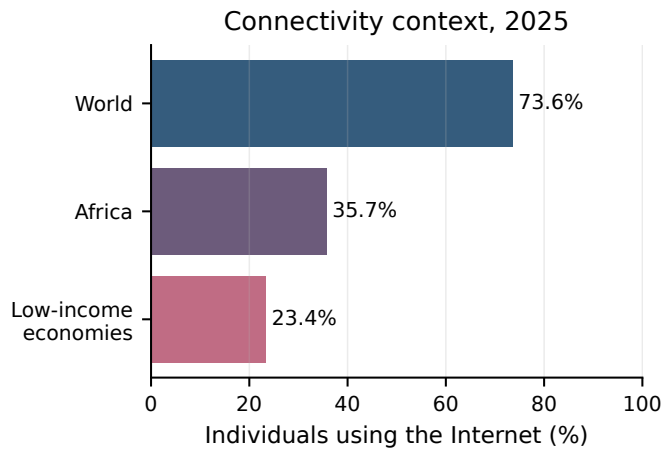


Fig. 1. Connectivity constraints relevant to digital-education architecture. Values are 2025 ITU estimates; the chart is generated from the included source-data file.

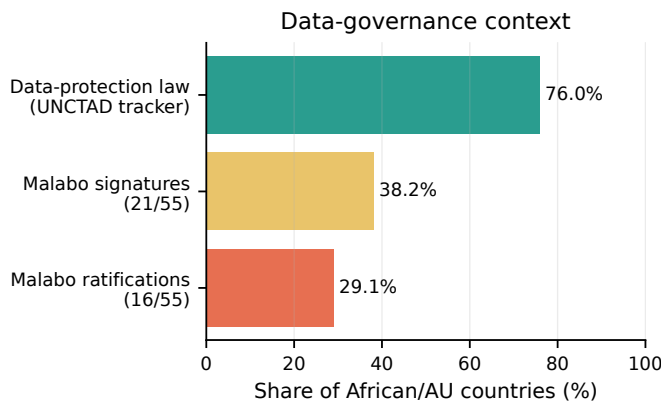


Fig. 2. Selected African data-governance indicators. The UNCTAD legislation indicator and AU treaty-status indicators use different concepts and denominators and are shown only as contextual signals.

Existing research provides important partial solutions. Learning-analytics work analyzes consent, transparency, autonomy, and institutional maturity [13]–[16]. Research on micro-credentials emphasizes portability and stakeholder coordination [17], [18]. Academic credential systems increasingly use cryptographic verification or distributed ledgers [19], [20],

while W3C Verifiable Credentials (VC) 2.0 now supplies a standards-based, machine-verifiable data model [21]. Yet the literature rarely joins these elements into an Africa-centered, jurisdiction-aware architecture that also treats low connectivity, workload identity, revocation, policy evidence, and privacy-preserving analytics as first-class concerns.

This paper addresses four research questions:

- **RQ1:** Which security, privacy, governance, interoperability, and resilience requirements arise when African digital-education services exchange data and credentials across institutional and national boundaries?
- **RQ2:** How can zero-trust controls and privacy-enhancing mechanisms be combined without assuming a single continental legal regime, universal connectivity, or a shared raw-record repository?
- **RQ3:** Under an explicit synthetic workload, how do purpose, lawful-basis, jurisdiction, and minimization predicates affect false permits, prohibited-transfer blocking, legitimate denial, and data disclosure?
- **RQ4:** What analytical coverage, local computational cost, policy-staleness sensitivity, and differential-privacy utility are observed under reproducible protocols?

The contributions are fivefold. First, the paper derives fourteen traceable engineering requirements from continental instruments, representative national transfer rules, current standards, and peer-reviewed educational-privacy research. Second, it proposes a layered architecture joining subject, device, and workload identity with purpose- and jurisdiction-aware authorization. Third, it formalizes permit decisions as policy predicates that return obligations, including field projection, retention, encryption, evidence, and revocation hooks. Fourth, it evaluates the design through a declared threat-control rubric, a 3,000,000-request synthetic policy experiment, a differential-privacy utility study, a registry-staleness sensitivity analysis, and a local microbenchmark. Fifth, it supplies scripts, source data, raw measurements, and vector figures in an Overleaf-ready artifact. No learner records, biometric samples, production logs, or named-country performance data are used.

II. BACKGROUND AND RELATED WORK

A. Continental and National Governance Context

The AU Data Policy Framework frames data as a strategic resource while emphasizing rights, security, interoperability, institutional coordination, and a shared African data space [2]. The 2025 AU Guidelines for Integrating Data Provisions in Protocols on Digital Trade reinforce harmonization and secure, inclusive cross-border data use [22]. For digital education, these directions imply that portability cannot be reduced to moving complete learner databases between cloud regions. A safer interpretation is to make transfer decisions explicit, purpose-bound, evidence-producing, and limited to the minimum data needed for a particular interaction.

National rules remain decisive. Morocco's Law No. 09-08 establishes personal-data protections, and the Commission Nationale de Contrôle de la Protection des Données à Caractère Personnel (CNDP) provides a notification and authorization pathway for transfers abroad [23], [24]. Kenya's Data Protection Act addresses transfers outside Kenya in Sections 48–50, with further operational detail in the 2021 General Regulations [25], [26]. South Africa's Protection of Personal Information Act (POPIA) includes transborder-flow conditions in Section 72 [27]. Institutions serving persons in the European Union may additionally confront the privacy-by-design and international-transfer requirements of GDPR Articles 25 and 44 [28]. These examples are not presented as an exhaustive legal survey. They demonstrate why an architecture should represent origin, destination, data category, purpose, legal basis, safeguards, retention, and downstream obligations as machine-enforceable attributes rather than static documentation.

The architecture in this paper is consequently *law-aware but not law-determining*. It provides technical hooks and evidence for competent institutional and legal decision-makers; it does not declare a transfer lawful, replace regulator guidance, or infer that identical controls satisfy every jurisdiction.

B. Zero Trust, Privacy Engineering, and Threat Modeling

Zero trust shifts protection from network segments to resources and requires continuous evaluation of subjects, devices, services, and contextual risk [7]. Cloud-native implementation further requires application identities, ingress and egress gateways, service-mesh enforcement, and policies that travel across locations [8]. This is especially relevant to education because an LMS, student-information system (SIS), assessment service, credential issuer, analytics pipeline, and payment service may be independently operated.

Privacy engineering adds objectives that conventional authorization does not express. The NIST Privacy Framework organizes privacy risk around identifying, governing, controlling, communicating, and protecting data processing [9]. NISTIR 8062 treats privacy as an engineering risk-management problem and encourages explicit privacy requirements and system-level analysis [10]. LINDDUN supplies a systematic vocabulary for privacy threats, including linkability, identifiability, non-repudiation, detectability, disclosure, unawareness, and non-compliance [29]. STRIDE-oriented security analysis, as operationalized in threat-modeling practice, complements it with

spoofing, tampering, repudiation, information disclosure, denial of service, and elevation of privilege [30]. The present threat model uses these frameworks as elicitation aids rather than claiming a formal certification against either method.

C. Learning Analytics and Learner Autonomy

Learning analytics can improve feedback and institutional decision-making, but centralizing fine-grained behavioral traces also creates surveillance, inference, and secondary-use risks. Hoel and Chen argue that educational benefit should constrain analytics design rather than allowing technical capability to define acceptable processing [11]. Jones proposes informed-consent mechanisms that strengthen student privacy and autonomy [12], while empirical work shows that students distinguish among data types and care about transparency and control [13]. Privacy frameworks influence system architecture, not merely notices and policies [14], [15]. The HELA-CMM maturity model further suggests that sustainable analytics adoption requires organizational capabilities in addition to software features [16]. Accordingly, the architecture separates operational records from privacy-enhanced analytics and requires purpose, minimization, and privacy-budget obligations for higher-risk queries.

D. Portable Credentials and Interoperability

Micro-credentials promise flexible recognition, yet systematic reviews identify unresolved issues around quality assurance, comparability, institutional acceptance, and technical interoperability [17], [18]. Blockchain-based diploma and identity models demonstrate the value of tamper evidence and decentralized verification [19], [20]; more recent work also combines zero-trust and decentralized-identity ideas for attack resistance [31]. Nevertheless, publishing raw personal or educational data to an immutable public ledger would conflict with minimization, correction, and erasure requirements. This paper therefore uses W3C VC 2.0 as the credential envelope, a trust registry for issuer metadata, and a privacy-preserving status mechanism for suspension or revocation [21], [32]. A ledger may anchor keys or governance records, but it is not required and must not hold raw learner data.

III. RESEARCH DESIGN

A. Design-Science Process and Evidence Protocol

The work follows the design-science sequence of problem identification, objective definition, artifact design, demonstration, evaluation, and communication [43]. The evidence synthesis is structured and purposive rather than a claim of exhaustive systematic review. Official sources were prioritized for standards, treaty status, policy, and legislation; peer-reviewed sources were used for privacy, analytics, credentials, and design methodology. The evidence cutoff is 18 August 2026.

The inclusion criteria were: (i) final standards or official instruments directly relevant to identity, privacy, cross-border transfer, digital education, or credentials; (ii) representative national rules from geographically and legally distinct African

TABLE II
POSITIONING AGAINST REPRESENTATIVE STANDARDS AND RESEARCH STREAMS

Stream	Representative evidence	Primary contribution	Gap addressed by AFRICA-ZT-EDU
Zero-trust architecture	NIST SP 800-207, SP 800-207A, SP 1800-35 [7], [8], [33]	Resource-centric access, explicit verification, deployment patterns, workload and service controls.	Adds purpose limitation, jurisdiction-aware transfer predicates, field-level minimization, educational credential lifecycles, and low-connectivity behavior.
Digital identity and phishing resistance	NIST SP 800-63-4 and WebAuthn Level 3 [34], [35]	Identity proofing, authentication assurance, federation, and public-key credentials.	Connects identity assurance to educational purpose, data category, destination profile, and decision obligations rather than treating authentication as sufficient authorization.
Attribute-based authorization	NIST SP 800-162 and service-mesh ABAC [36], [37]	Policy decisions over subject, object, operation, environment, and service attributes.	Adds legal/governance attributes, transfer admissibility, minimum claim views, evidence receipts, and freshness-aware policy registries.
Privacy engineering and learning analytics	NIST Privacy Framework; educational privacy and autonomy literature [9]–[12], [16]	Privacy-risk management, consent, transparency, autonomy, and institutional maturity.	Makes privacy obligations executable at access and transfer time and separates operational records from privacy-enhanced analytics.
Portable academic credentials	W3C VC 2.0, status list, micro-credential and diploma systems [17], [19]–[21], [32]	Tamper-evident claims, issuer-holder-verifier exchange, status, and credential portability.	Integrates credential verification with issuer governance, purpose-specific disclosure, revocation freshness, offline limits, and access policy.
Federated and privacy-preserving analytics	Federated learning, secure aggregation, differential privacy [38]–[41]	Distributed computation and bounded aggregate disclosure.	Places PET selection inside an educational governance workflow with cohort floors, budgets, query evidence, and residual-risk treatment.
African data and digital-education governance	AU Data Policy Framework, AU Digital Education Strategy, AfCFTA Digital Trade Protocol and guidelines [1], [2], [22], [42]	Harmonization, trusted data use, interoperability, digital transformation, and secure cross-border activity.	Translates policy directions into a common machine-enforceable schema while preserving institution- and jurisdiction-specific review.

TABLE III
DESIGN-SCIENCE AND EVALUATION PROCEDURE

Step	Activity	Traceable output
1	Problem framing	Assets, actors, trust boundaries, jurisdiction and connectivity constraints.
2	Evidence synthesis	Primary standards and instruments plus peer-reviewed privacy, credential, and education research.
3	Requirement derivation	Fourteen requirements with operational acceptance criteria.
4	Artifact construction	Layered architecture, decision model, transfer workflow, credential lifecycle, and failure policy.
5	Threat analysis	12 threats $\times$ 3 objectives with declared 0/0.5/1 rubric and row-level rationales.
6	Policy simulation	3,000,000 synthetic requests, 30 seeds, two baselines, 95% intervals, minimization and transfer metrics.
7	Technical demonstration	DP utility, policy-staleness sensitivity, and single-host cryptographic/policy microbenchmark.
8	Validity controls	Source primacy, declared assumptions, no real personal data, raw outputs, scripts, and environment metadata.

jurisdictions; (iii) peer-reviewed research with an explicit design, privacy, credential, or learning-analytics contribution; and (iv) sufficient bibliographic provenance for independent retrieval. Vendor marketing, undocumented product claims, unofficial legal summaries where primary text was available, and draft standards superseded by final recommendations were excluded. Table III records the transformation from evidence to evaluation.

B. System Scope and Assumptions

The target is a federation of higher-education, professional-training, and continuing-education platforms. In-scope assets are identity attributes, contact details, enrollment, grades, assessment submissions, credential claims, payment references, proctoring records, consent and rights requests, and learning-event data. In-scope actors are learners, educators, registrars, institutional administrators, employers, partner institutions,

cloud or software providers, regulators, attackers, and malicious or coerced insiders.

The architecture assumes that each participating institution remains accountable for its own legal and educational decisions; cryptographic keys are managed through institutionally controlled key-management or hardware-security boundaries; jurisdiction profiles are reviewed by competent personnel; and service identities can be provisioned. It does *not* assume uniform law, constant connectivity, universal smartphone ownership, a public blockchain, or mutual trust among every participant.

C. Derived Requirements

Table IV presents the requirements. Their purpose is not to encode legislation directly, but to translate recurring obligations and risks into testable system behavior.

IV. PROPOSED REFERENCE ARCHITECTURE

A. Design Principles

The architecture is guided by six principles. First, *verify each access path*: subject, device, and workload identities are distinct signals. Second, *make purpose enforceable*: an authorization request without an approved educational purpose cannot be permitted merely because the user has a broad role. Third, *move claims rather than databases*: authoritative records remain in controlled zones, while cross-border services receive purpose-specific views. Fourth, *separate evidence from exposure*: immutable or append-only records contain decision metadata and digests, not raw personal data. Fifth, *degrade safely*: offline or low-bandwidth behavior is bounded by risk and freshness. Sixth, *prefer interoperable interfaces*: identity, credentials, status, policy schemas, and exports should not require a single vendor.

TABLE IV
TRACEABLE ENGINEERING REQUIREMENTS AND ACCEPTANCE EVIDENCE

ID	Requirement	Operational interpretation	Minimum acceptance evidence
R1	Explicit identities	Authenticate the human subject, device context, and calling workload before protected-resource access.	Distinct subject/device/workload assertions; issuer and audience verification; expired or wrong-audience assertions denied.
R2	Phishing-resistant access	Prefer public-key authenticators for privileged and high-impact workflows; bind recovery to risk and audit.	Passkey/WebAuthn test for privileged roles; recovery simulation; step-up and revocation logs [34], [35].
R3	Least privilege	Issue short-lived, resource- and action-scoped authorization and re-evaluate high-risk actions.	Deny-path tests for role, relationship, action, expiry, and device-risk changes [7], [8].
R4	Purpose limitation	Require a declared, allowed educational purpose independent of the user's broad role.	Purpose catalog; policy tests showing identical role/resource pairs produce different decisions by purpose.
R5	Governed transfer	Evaluate origin, destination, category, purpose, basis/safeguard, recipient assurance, retention, and onward transfer.	Versioned jurisdiction profiles; blocked-transfer tests; approval evidence and decision receipt [22], [24], [25], [27].
R6	Data minimization	Release only the fields/claims required by the approved purpose and destination profile.	Field-projection tests; schema diff; denied access to non-projected fields; minimization metrics.
R7	Regional authority	Keep authoritative records in approved zones and exchange bounded claim views instead of default database replication.	Data-flow map; key-domain separation; recipient cannot dereference a minimized view into the source record.
R8	Learner rights	Support notice/consent where applicable, correction, export, objection, deletion/retention decisions, and appeal.	Rights-request workflow, identity verification, decision rationale, completion timestamps, and audit trail [9], [12].
R9	Credential integrity	Verify issuer trust, signature, schema, validity period, audience, and status; separate cryptographic validity from academic recognition.	Positive/negative VC vectors, revoked/suspended status tests, unknown-issuer denial, and issuer-governance record [21], [32].
R10	Privacy-enhanced analytics	Prefer aggregation/federation where raw-event pooling is unnecessary; apply cohort floors, clipping, budgets, and query evidence.	Privacy-budget ledger, repeated-query tests, small-cohort denial, model leakage assessment [38]–[40].
R11	Continuous telemetry	Correlate identity, device, workload, gateway, egress, data-access, and credential-status events.	Common event schema, time synchronization, anomaly detection, alert-to-containment drill, and retention policy.
R12	Low-connectivity resilience	Support local-first content, compact tokens, asynchronous audit buffering, and bounded offline verification.	Packet-loss/offline tests; freshness-window enforcement; queued-event reconciliation; fail-closed tests for high-risk operations.
R13	Coordinated response	Support session and credential revocation, key rotation, transfer suspension, evidence preservation, and notification workflow.	Incident playbook, key-rotation drill, status propagation test, transfer scoping, and restoration evidence.
R14	Accountability and portability	Sign decision receipts, version policies, test configurations, retain open exports, and exercise vendor exit.	Receipt verification, policy rollback test, configuration diff, standards-based export, and documented migration rehearsal.

B. Decision Model

An access or transfer request is represented as

$$q = \langle s, d, w, r, a, p, j_o, j_d, c, b, t \rangle, \quad (1)$$

where s is the subject, d the device context, w the workload identity, r the resource, a the action, p the declared purpose, j_o and j_d the origin and destination jurisdictions, c the data category, b the transfer basis or approved safeguard profile, and t the temporal context.

A permit decision is issued only if

$$\begin{aligned} \text{Permit}(q) \Leftrightarrow & A_s(s) \wedge A_d(d) \wedge A_w(w) \\ & \wedge L(s, r, a, p) \wedge X(j_o, j_d, c, p, b) \\ & \wedge M(r, p, c) \wedge \rho(q) < \tau, \end{aligned} \quad (2)$$

where A_s , A_d , and A_w are authentication predicates; L is the local authorization predicate; X is the jurisdiction and transfer predicate; M verifies that the selected field set is no larger than the purpose-specific allow-list; $\rho(q)$ is a risk score; and τ is the applicable threshold. A positive decision returns obligations rather than a bare Boolean:

$$O(q) = \{F, T_{\text{exp}}, E, R_t, \Gamma, \Delta\}, \quad (3)$$

where F is the field projection, T_{exp} the token or view expiry, E encryption requirements, R_t retention, Γ logging and notification duties, and Δ downstream deletion or revocation hooks. This structure allows an institution to change a jurisdiction profile without rewriting every application.

C. Identity, Device, and Workload Plane

Learners and staff authenticate through federated OpenID Connect or equivalent institutional identity, with phishing-resistant passkeys preferred for higher-risk roles. Device posture

is a contextual signal, not a permanent identity guarantee. Services receive distinct workload identities, preferably short-lived and automatically rotated, so that an LMS calling a credential issuer is not authorized merely because both applications reside in the same virtual network. Policy-enforcement points (PEPs) at APIs and service gateways send normalized requests to a policy decision point (PDP), which evaluates Equation (2). High-risk actions—such as bulk grade export, proctoring-data access, key administration, or cross-border release of special-category data—require stronger device posture, step-up authentication, or dual approval.

D. Jurisdiction-Aware Transfer Gateway

The transfer gateway is the architectural distinction between ordinary attribute-based access control and governed cross-border processing. A jurisdiction registry contains reviewed policy profiles: recognized purposes, data categories, prohibited fields, approved bases or safeguards, retention ceilings, recipient classes, onward-transfer constraints, and incident contacts. A transfer request must identify the recipient and declared purpose; the PDP then selects a field projection and obligations. The gateway records a signed decision receipt containing policy version, request digest, decision, selected fields, expiry, destination, and responsible institutional role. Raw values are not written to the receipt.

Table VII illustrates the mapping. The entries are engineering interpretations for traceability, not legal opinions.

E. Regional Data and Privacy Plane

Authoritative SIS and assessment records are placed in approved encrypted data zones. Fields are classified by sensitivity

AFRICA-ZT-EDU reference architecture

Policy-governed, Zero-Trust, privacy-preserving and jurisdiction-aware decision path

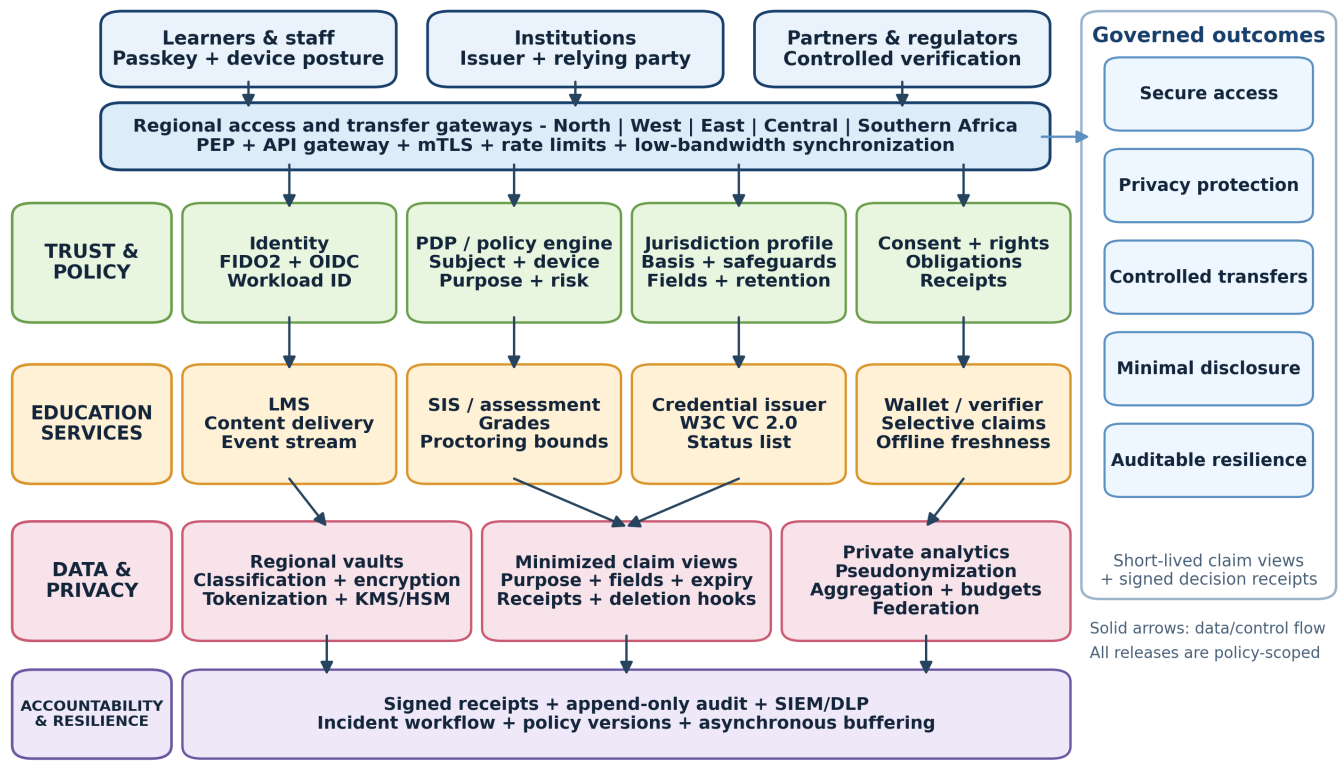


Fig. 3. Proposed reference architecture. A policy decision joins identity, device, workload, purpose, risk, jurisdiction, transfer basis, and minimization obligations before regional data zones release a claim view. The high-resolution diagram is an implementation-neutral logical model; arrows are routed outside component boxes to preserve traceability and legibility.

and purpose, with independent keys or envelope-encryption domains for identity, academic, financial, and proctoring data. Tokenization or pseudonymization reduces exposure to analytics and support services. A cross-border recipient receives a time-bounded claim view, such as “credential valid, six credits, distinction band,” rather than the learner’s full profile and event history.

For analytics, the platform prefers aggregate or federated computation when the educational question does not require raw-event pooling. Privacy budgets, minimum cohort sizes, query logging, and disclosure review can reduce inference risk. These mechanisms do not make analytics risk-free: trained models may retain information, small populations can be re-identified, and institutional incentives can expand purposes. The architecture therefore leaves residual risk for T9 rather than assigning full analytical coverage.

F. Credential Lifecycle

An institution issues a VC after its internal academic decision is complete. The credential contains only required claims, an issuer identifier, validity information, and a status reference. The holder stores it in a wallet or institution-provided account. A verifier requests a claim set tied to a declared purpose; the holder or presentation service discloses only those claims. The verifier validates issuer metadata, signature, schema, time

bounds, and status freshness. High-risk decisions fail closed when current status cannot be obtained. Lower-risk verification may use a signed cached status object within a formally bounded offline window, with the stale-state condition recorded in the decision receipt.

This design deliberately separates academic truth from cryptographic proof. A signature proves origin and integrity, not educational quality or legal recognition. Governance bodies must still define issuer eligibility, assurance levels, appeals, corrections, and revocation authority. The credential layer therefore complements rather than replaces quality assurance.

G. Low-Connectivity and Failure Modes

Connectivity constraints in Fig. 1 affect every control. The design supports compact tokens, progressive synchronization, offline content packages, local queues for signed audit events, and asynchronous policy updates with version checks. Availability is risk-tiered: routine content access can continue from a local cache; credential presentation can continue within a signed freshness window; but bulk export, administrator elevation, key changes, and sensitive transfer are denied when central policy or current status is unavailable. When connectivity returns, queued audit events are hash-linked, time-checked, and reconciled. Conflict handling favors the most restrictive

TABLE V
AUTHORIZATION INPUT ATTRIBUTES AND EXAMPLE EVIDENCE

Category	Core attributes	Illustrative evidence source	Security/privacy purpose
Subject	Stable or pairwise identifier, role, affiliation, assurance level, relationship, delegation.	Institutional IdP, verified credential, registrar relationship service.	Establish who is requesting and the relationship to the resource without relying on network location.
Device/session	Device posture, authenticator type, session age, token binding, anomaly/risk signals.	Device trust service, WebAuthn assertion, session telemetry.	Reduce account-takeover and replay risk; trigger step-up or denial.
Workload	Service identifier, deployment identity, software provenance, calling chain, certificate/key state.	Workload identity system, mTLS certificate, signed deployment metadata.	Prevent one service from inheriting another service's privileges.
Resource/action	Resource class, owner/tenant, sensitivity, action, volume, field set, export flag.	Data catalog, API schema, object metadata, request.	Apply least privilege, rate/volume limits, and field projection.
Purpose/basis	Declared purpose, compatible use, legal/governance basis, approval state, retention reason.	Purpose catalog, consent/contract/mandate registry, review workflow.	Prevent secondary use and make purpose enforceable rather than documentary.
Jurisdiction/recipient	Origin, destination, recipient class, assurance, transfer condition, onward-transfer rule.	Reviewed jurisdiction profile, partner registry, contract/safeguard metadata.	Decide whether a cross-border release is permitted and under which obligations.
Time/status/risk	Policy version, time, credential/status freshness, threat signals, emergency state.	Policy registry, status list, SIEM, risk engine.	Bound offline use, prevent rollback, and adapt decisions to current risk.

TABLE VI
DECISION OUTCOMES AND MANDATORY EFFECTS

Outcome	Mandatory effect
Permit	Release the approved minimized view with short expiry and record policy/evidence metadata.
Permit with obligations	Enforce field projection, encryption, retention, notification, rate, deletion, and downstream-use constraints.
Step-up required	Obtain stronger subject/device assurance or dual approval, then re-evaluate the entire request.
Manual review	Pause release; route to a competent institutional role with the evaluated facts and policy version.
Deny	Release no protected values; return a non-sensitive reason category and preserve audit evidence.
Emergency permit	Use only an authorized break-glass policy; minimize fields, shorten expiry, alert reviewers, and require post-event review.

valid policy version unless an authorized emergency procedure is invoked and separately recorded.

V. THREAT MODEL AND EVALUATION

A. Threat Elicitation

The threat model combines security and privacy prompts from STRIDE and LINDDUN [29], [30]. Trust boundaries occur between user devices and access gateways, gateways and the PDP, services and regional data zones, credential issuers and wallets, institutions and external verifiers, and operational systems and analytics. Table VIII summarizes twelve high-priority threats. It is not an exhaustive attack tree; rather, it is the evaluation frame for the reference architecture.

B. Analytical Coverage Rubric

Each threat is scored across three objectives: (i) prevent or minimize; (ii) detect or verify; and (iii) contain, recover, or account. A score of 0 means the reference profile contains no explicit mechanism; 0.5 means a partial, manually dependent, or non-integrated mechanism; and 1 means the architecture contains an explicit, traceable mechanism. The perimeter-centric reference profile assumes password-centered authentication, optional MFA, static broad roles, ordinary centralized logs, generic encryption in transit and at rest, application-specific revocation, cloud redundancy, and manual cross-border review.

It is a constructed comparator, not a measurement of a named product.

The proposed architecture scores 34 of 36 possible points (94.4%), while the comparator scores 15 of 36 (41.7%). Figure 4 shows per-threat results. Full scores are withheld for analytics leakage because privacy loss cannot always be detected or reversed; for connectivity disruption because monitoring itself can fail; and for policy misconfiguration because conformance tests do not prove semantic correctness. The scoring demonstrates requirement-to-control traceability, not exploit resistance. Independent red-team testing and operational evidence are required before deployment claims.

C. Synthetic Policy-Expressiveness Evaluation

The second evaluation component tests whether the proposed predicates express a declared synthetic policy truth more precisely than two baselines. It does not estimate real attack frequency, institutional error rates, or legal compliance. The generator creates 100,000 requests for each of 30 independent seeds, producing 3,000,000 decisions. Twenty-four synthetic institutions are distributed across 12 abstract jurisdiction profiles; no country names are assigned. Four profiles are configured in each of three experimental classes: strict residency, conditional transfer, and interoperable/trusted flow. These labels are test constructs rather than assessments of actual jurisdictions.

Requests contain six roles, six resource classes, five actions, six purposes, five basis states, identity assurance, device posture, session age, relationship state, risk, source and destination profiles, and cross-border status. Thirty-eight percent of requests are configured to cross a jurisdiction. A controlled 18% misuse tail independently samples role/resource/action combinations. Resource schemas contain 8–24 fields, and purpose-specific release profiles contain 2–9 fields. Across seeds, 24.572% of requests satisfy all ground-truth predicates; this is an intentionally stress-oriented distribution, not a traffic estimate.

Let $y_i \in \{0, 1\}$ be the ground-truth permit label and $\hat{y}_i$ the architecture decision. The false-permit rate is calculated over invalid requests,

$$\text{FPR} = \frac{\sum_i \mathbb{I}(\hat{y}_i = 1 \wedge y_i = 0)}{\sum_i \mathbb{I}(y_i = 0)}, \quad (4)$$

TABLE VII
ILLUSTRATIVE INSTRUMENT-TO-ARCHITECTURE MAPPING

Instrument or source	Engineering implication	Architecture mechanism
AU Data Policy Framework [2]	Harmonization, rights protection, trust, shared data spaces, and accountable use should coexist.	Common policy schema, regional data zones, rights workflow, portable receipts, and standards-based interfaces.
AU Digital Education Strategy [1]	Adoption must account for skills, devices, networks, languages, and institutional capacity.	Low-bandwidth synchronization, local-first content, staged deployment, and bounded offline credential verification.
AfCFTA Digital Trade Protocol and AU data guidelines [22], [42]	Cross-border digital activity should be trustworthy, interoperable, transparent, and supported by common principles.	Jurisdiction registry, transfer predicate, safeguard metadata, interoperable APIs, and evidence-producing gateways.
Malabo Convention [5]	Cybersecurity and personal-data protection require organizational and technical safeguards and coordinated accountability.	Security/privacy co-design, incident workflow, key rotation, transfer suspension, and evidence preservation.
Morocco Law 09-08 and CNDP process [23], [24]	International transfers may require a documented condition, procedure, or authorization.	Transfer-basis attribute, workflow state, destination profile, approval evidence, and receipt.
Kenya Data Protection Act and Regulations [25], [26]	Transfer conditions and safeguards must be demonstrable.	Safeguard profile, recipient assurance, category rules, and auditable transfer register.
South Africa POPIA Sec. 72 [27]	Transborder processing depends on recipient protections or another recognized condition.	Destination assurance, contractual/safeguard metadata, purpose, necessity, and onward-transfer checks.
GDPR Arts. 25 and 44 [28]	Privacy by design/default and controlled international transfers affect institutions handling EU-linked data.	Default-minimized projections, transfer predicate, retention obligations, rights workflow, and accountability evidence.
W3C VC 2.0 and status list [21], [32]	Credentials should be interoperable, verifiable, privacy-respecting, and lifecycle-managed.	Issuer/verifier interfaces, selective presentation, trust registry, signed status, and freshness policy.

TABLE VIII
THREAT SET, PRINCIPAL CONTROLS, AND RESIDUAL CONCERNS

ID	Threat	Principal architecture controls	Important residual concern
T1	Phishing/account takeover	Passkeys, device context, risk-aware PDP, short-lived tokens, recovery controls, rapid revocation.	Recovery and social-engineering processes remain exploitable.
T2	Stolen bearer/session token	Proof-bound or mutually authenticated tokens, context checks, replay analytics, resource scope [44], [45].	A compromised client can act within a still-valid session.
T3	Compromised endpoint	Device posture, step-up, per-resource decisions, least privilege, containment.	Posture signals are incomplete and may be forged or delayed.
T4	Overprivileged administrator	Just-in-time privilege, purpose constraints, dual approval, segregated keys, decision receipts.	Authorized insiders can collude or misuse legitimate workflows.
T5	Unlawful/excessive transfer	Jurisdiction registry, transfer predicate, field projection, expiry, recipient assurance, approval evidence.	Incorrect legal profiles or institutional interpretation can authorize an improper flow.
T6	API scraping/exfiltration	Workload identity, rate/volume controls, egress DLP, field minimization, anomaly detection.	Slow distributed extraction may evade thresholds.
T7	Credential forgery	Issuer signatures, trust registry, schema validation, status verification, verifier receipts.	Compromised issuer keys or fraudulent issuers remain governance risks.
T8	Revocation bypass	Signed status, freshness policy, high-risk fail-closed behavior, bounded cached status.	Offline acceptance creates a deliberate time-limited exposure window.
T9	Analytics inference/privacy leakage	Pseudonymization, aggregation, cohort floors, privacy budgets, secure aggregation, federated analysis.	Models, repeated queries, and small populations can retain or reveal information.
T10	Audit tampering/repudiation	Signed receipts, append-only storage, hash linkage, key segregation, replication.	Endpoint compromise can falsify events before capture.
T11	Disruption/intermittent connectivity	Regional zones, local-first content, bounded offline verification, asynchronous buffering.	Severe outages and device loss still interrupt high-risk operations.
T12	Lock-in/policy misconfiguration	Open standards, policy as code, conformance tests, simulation, versioned rollback, portable exports.	Semantic errors and proprietary extensions cannot be eliminated architecturally.

while permit precision is $\sum_i \mathbb{1}(\hat{y}_i = 1 \wedge y_i = 1) / \sum_i \mathbb{1}(\hat{y}_i = 1)$. The prohibited-transfer block rate is evaluated only over requests that pass contextual, purpose, and basis checks but fail the ground-truth cross-border predicate. The field metric is the mean number of released fields over permitted requests. For each metric, the artifact reports the mean across 30 seeds and a two-sided 95% normal-approximation interval, $\bar{x} \pm 1.96s/\sqrt{30}$. The raw per-seed values are included so alternative intervals can be computed.

The results answer RQ3 within the model. Coarse RBAC permits many requests that violate purpose, identity-context, or transfer truth. Contextual ABAC removes a large share of those errors but cannot distinguish an otherwise legitimate request whose purpose, basis, or destination profile makes the release invalid. The full architecture reduces the false-permit rate to 0.0095%, with the remaining error produced by deliberately stale false-allow registry entries. The 0.104% legitimate-denial

rate is likewise produced by configured stale false-deny entries. Purpose-bound field projection reduces the mean disclosed schema from 12.702 to 4.920 fields, a 61.26% reduction. These quantities demonstrate generator-level policy expressiveness; they do not imply equivalent reductions in production breaches or legal risk.

D. Registry-Staleness and Differential-Privacy Sensitivity

Because the jurisdiction registry is a governance dependency, the artifact isolates its failure mode over 200,000 otherwise-valid prohibited-transfer candidates. The observed escape rate tracks the configured stale/incorrect false-allow rate almost linearly. At 0.25% stale entries, 0.2525% of prohibited candidates escape; at 1%, 0.9980% escape; at 5%, 5.0045% escape. This result is intentionally unsurprising: it quantifies why signed updates, review ownership, rollback protection, freshness limits,

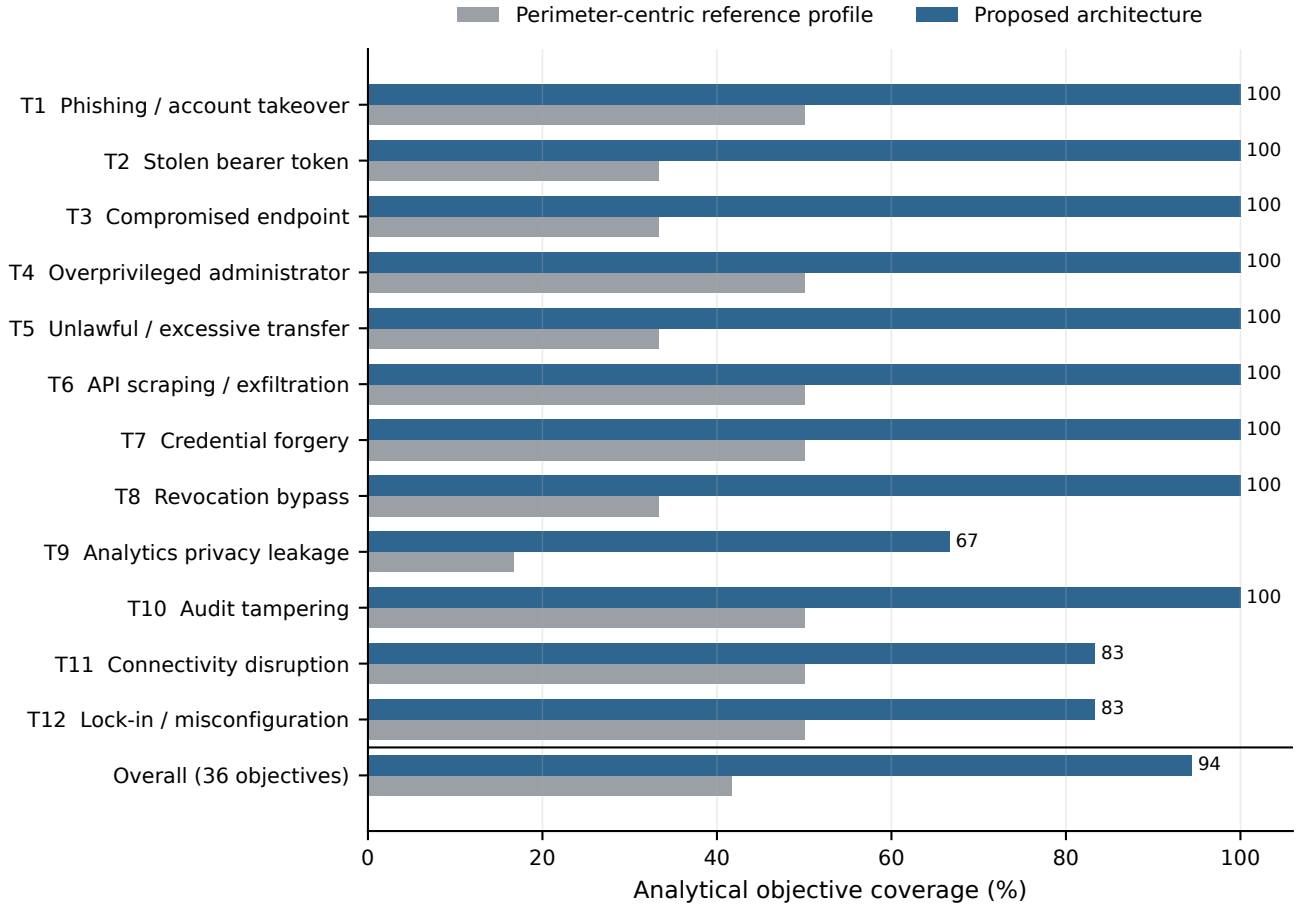


Fig. 4. Analytical coverage under the declared 0/0.5/1 rubric. The proposed design reaches 34/36 objectives; the constructed perimeter-centric reference profile reaches 15/36. Values represent explicit architectural control presence, not empirical breach probability.

and fail-closed behavior are architectural requirements rather than administrative details.

The DP utility experiment applies Laplace noise to 50,000 synthetic cohort counts with cohort sizes from 25 to 250. At $\epsilon = 1$, the median absolute error is 0.550 percentage points, the mean is 1.018, and the 95th percentile is 3.591. Lower ϵ improves formal privacy but increases error; higher ϵ reduces error while weakening the per-query privacy guarantee. Production analytics would additionally require composition accounting, clipping, contribution limits, minimum cohort sizes, repeated-query controls, and leakage testing.

E. Reproducible Microbenchmark

The computational demonstration measures operations expected at a policy gateway: Ed25519 signing and verification of a canonical 720-byte VC-like payload; AES-256-GCM encryption and decryption for 1, 10, and 100 KiB buffers; sequential first-match policy evaluation over 50 and 200 rules; and a composite gate containing signature verification, a conservative 200-rule scan with the permit rule placed last, encryption of a 10 KiB payload, and generation of a hashed decision receipt.

The benchmark uses Python 3.13.5, cryptography 46.0.4, and NumPy 2.3.5 on an x86_64 Linux host. It warms each

operation before recording samples and publishes both raw and summary CSV files. All payloads are synthetic. The benchmark excludes network, database, key-management appliance, orchestration, storage, user-interface, and remote identity-provider latency. It therefore estimates local computational cost, not production response time.

Ed25519 verification is the largest measured component of the composite path. Increasing the conservative sequential rule set from 50 to 200 raises median policy latency from 0.0016 to 0.0048 ms, consistent with a near-linear scan at this scale. The composite gate records 0.1210 ms median and 0.1384 ms p95. These results indicate that the local policy and cryptographic operations need not dominate a typical Internet-mediated educational request. They do not establish performance on mobile devices, hardware security modules, congested networks, multi-region databases, or production policy engines.

VI. DISCUSSION

A. RQ1: Requirements Are Joint, Not Sequential

The evidence synthesis shows that cross-border educational architecture cannot be designed as “security first, compliance later.” Identity assurance, purpose limitation, minimization,

TABLE IX
SYNTHETIC POLICY-EVALUATION CONFIGURATION

Parameter	Configured value	Interpretation / validity boundary
Requests and repetitions	100,000 per seed; 30 independent seeds; 3,000,000 total	Confidence intervals summarize between-seed variation under a fixed generator.
Institutions and jurisdictions	24 synthetic institutions; 12 abstract profiles	No real institution or country is represented, ranked, or assigned a result.
Intended cross-border share	38%	Produces enough cross-jurisdiction cases for transfer-policy stress testing.
Policy classes	Strict residency, conditional transfer, interoperable/trusted flow	Abstract generator classes, not legal labels for countries.
Baselines	Legacy RBAC; contextual zero-trust ABAC	Legacy uses coarse role/resource/action logic; ABAC adds context but omits purpose, basis, and jurisdiction predicates.
Proposed design	Contextual ABAC + purpose + basis + jurisdiction + minimization + receipt	Tests the incremental expressiveness of the complete decision model.
Policy staleness in main run	0.25% false-allow and 0.10% false-deny transfer entries	Models registry error explicitly; it is not inferred from observed institutions.
Modeled latency scope	In-process synthetic policy components; network RTT excluded	Used only for relative architectural modeling, not deployment capacity planning.
DP utility study	50,000 synthetic cohort-count queries; $\epsilon \in \{0.25, 0.5, 1, 2, 4, 8\}$	Illustrates a privacy-utility trade-off; no learner outcome is analyzed.

TABLE X
POLICY-EVALUATION RESULTS ACROSS 30 SEEDS (MEAN AND 95% CONFIDENCE INTERVAL)

Architecture	False permit %	Permit precision %	Legitimate denial %	Blocked prohibited transfer %	Mean fields disclosed	Modeled p95 ms
Legacy RBAC	77.042 [76.978, 77.106]	29.718 [29.663, 29.773]	0.000 [0.000, 0.000]	0.000 [0.000, 0.000]	12.702 [12.691, 12.712]	1.917 [1.915, 1.919]
Zero-Trust ABAC	10.039 [9.995, 10.084]	76.442 [76.353, 76.532]	0.000 [0.000, 0.000]	0.000 [0.000, 0.000]	12.702 [12.691, 12.712]	6.344 [6.338, 6.349]
AFRICA-ZT-EDU	0.0095 [0.0082, 0.0108]	99.971 [99.967, 99.975]	0.104 [0.095, 0.112]	99.750 [99.716, 99.785]	4.920 [4.917, 4.924]	9.121 [9.114, 9.128]

TABLE XI
SENSITIVITY RESULTS FOR POLICY REGISTRY STALENESS AND DIFFERENTIAL PRIVACY

Stale transfer entries %	Prohibited-transfer escape %	Blocked %	ϵ	Median abs. error (pp)	95th-ptl abs. error (pp)
0.00	0.0000	100.0000	0.25	2.1957	14.6139
0.10	0.1010	99.8990	0.50	1.1094	7.2606
0.25	0.2525	99.7475	1.00	0.5497	3.5913
0.50	0.4870	99.5130	2.00	0.2727	1.7944
1.00	0.9980	99.0020	4.00	0.1359	0.9254
2.00	1.9715	98.0285	8.00	0.0686	0.4567
5.00	5.0045	94.9955	–	–	–

TABLE XII
SELECTED SINGLE-HOST MICROBENCHMARK RESULTS

Operation	n	p50 ms	p95 ms
Ed25519 sign, 720 B	5000	0.0326	0.0442
Ed25519 verify, 720 B	5000	0.1028	0.1231
AES-GCM encrypt, 10 KiB	3000	0.0019	0.0021
Policy scan, 50 rules	6000	0.0016	0.0016
Policy scan, 200 rules	4000	0.0048	0.0052
Composite authorization gate	2500	0.1210	0.1384

transfer conditions, learner rights, credential integrity, accountability, and resilience interact. A passkey can reduce account takeover but does not justify exporting an entire learner profile. A signed credential can establish origin and integrity but does not establish academic quality or recognition. A local data region can support control over authoritative records but does not prove that a processing purpose is necessary. R1–R14 therefore form a coupled control system rather than an optional

checklist.

The context indicators also caution against claims of continental uniformity. A broad trend toward privacy legislation coexists with different transfer rules, regulator procedures, institutional capacities, and treaty participation. The appropriate technical response is a shared control vocabulary with reviewed institution- and jurisdiction-specific profiles, not a lowest-common-denominator rule and not 55 unrelated application designs.

B. RQ2: A Policy-Gated Claim Architecture

The central design choice is to combine zero-trust authorization with privacy and transfer obligations. Conventional ABAC asks whether a subject may perform an action on a resource. The proposed PDP additionally asks why the action is needed, which recipient and destination are involved, which data category is requested, which basis or safeguard has been approved, which fields are proportionate, how long the view

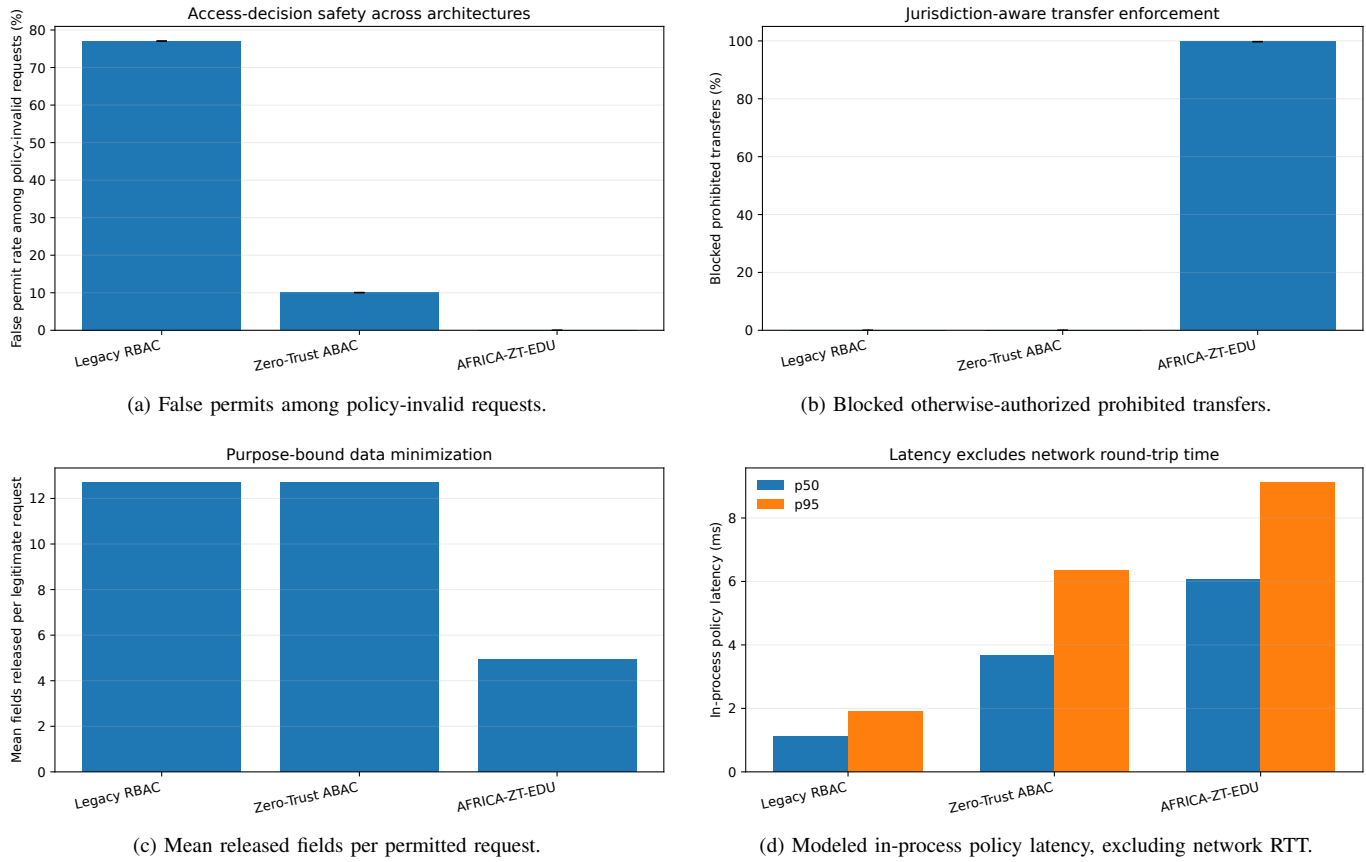


Fig. 5. Synthetic policy-evaluation results. Error bars are 95% intervals across 30 seeds; the y-axis and scope differ by panel. Latency is generated by the declared simulator and is not the measured microbenchmark reported later.

should live, and what evidence must be retained. The output is therefore a short-lived minimized claim view plus enforceable obligations and a signed receipt.

This pattern avoids two extremes. Blanket localization can fragment course collaboration and credential recognition, while unrestricted replication exposes complete records to unnecessary institutions, jurisdictions, and vendors. Regional authoritative zones with controlled claim exchange preserve interoperability without assuming that every service should store the source database. The same pattern can support course consortia, credit transfer, joint programs, professional credentials, employer verification, and regulator review.

C. RQ3: Policy Expressiveness, Minimization, and Registry Quality

Within the declared generator, purpose, basis, jurisdiction, and field-projection predicates materially change decision quality. Zero-trust ABAC reduces the false-permit rate relative to coarse RBAC, but it still lacks the information needed to reject an otherwise context-valid prohibited transfer. The proposed architecture's remaining false permits and legitimate denials are driven by deliberately injected registry staleness. Consequently, the strong result should not be read as a generic algorithmic guarantee: it demonstrates that the richer model can express the synthetic ground truth when its policy data are current.

The minimization result is equally important. The architecture releases an average of 4.920 fields rather than 12.702, reducing the disclosure surface by 61.26% for permitted synthetic requests. This metric does not prove that the selected fields are legally minimal in a real case. It shows that field projection can be made explicit, testable, and measurable instead of being left to application developers.

D. RQ4: Coverage, Local Cost, and Privacy Utility

The 34/36 analytical score improves because controls are explicit and cross-linked rather than isolated. The strongest gains occur for token replay, compromised devices, governed transfer, credential status, and evidence integrity. Full scores are intentionally withheld for analytics leakage, connectivity, and semantic policy error. A 100% score would conceal irreducible and organizational risks.

The microbenchmark supports a narrower performance conclusion: selected local cryptographic and policy operations are computationally modest on the recorded host. It cannot establish end-to-end service-level objectives. Production pilots must measure remote identity-provider latency, database/cache behavior, hardware-backed keys, policy distribution, mobile-wallet verification, packet loss, regional failover, and audit ingestion. Similarly, the DP study shows a tunable utility trade-off for synthetic counts, not that every learning-analytics task should or can use the same mechanism.

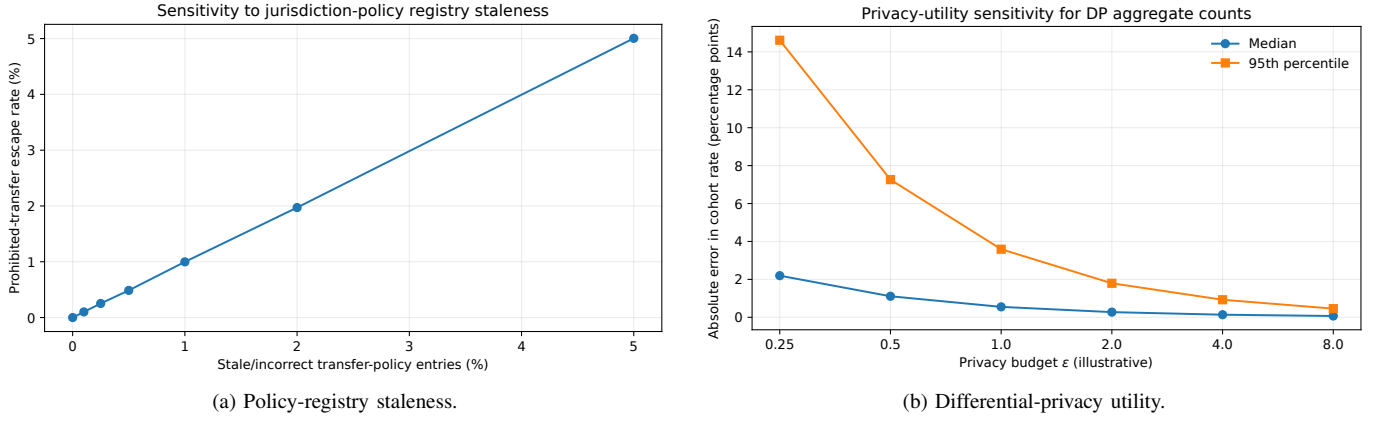


Fig. 6. Sensitivity analyses. The left panel isolates incorrect transfer-policy entries; the right panel uses synthetic count queries and reports error in percentage points. Neither panel is a country-level observation.

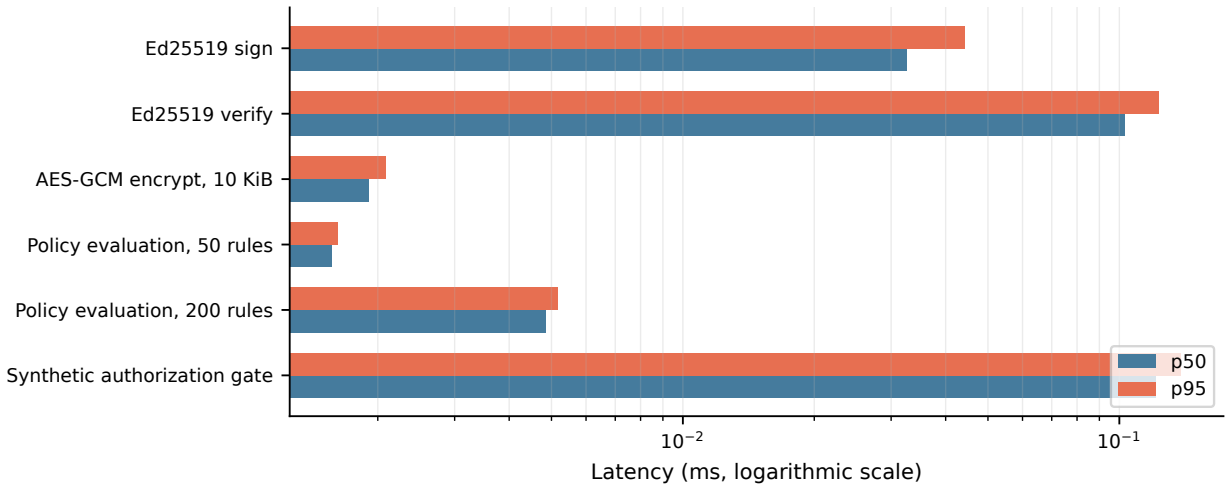


Fig. 7. Median and 95th-percentile latency for selected synthetic operations. The logarithmic horizontal axis exposes both cryptographic verification and lower-latency policy/encryption operations.

E. Deployment Roadmap

A staged deployment reduces both security and institutional risk. Each phase should include accessibility, language, low-bandwidth, and usability testing, because a cryptographically strong workflow that learners cannot understand can shift risk to shared accounts, unsafe recovery, help-desk impersonation, and exclusion.

F. Governance and Assurance

The architecture requires governance artifacts alongside code: a data and purpose catalog; jurisdiction-profile ownership; key-management policy; issuer onboarding criteria; credential schema governance; revocation authority; privacy-impact and transfer-assessment templates; rights and appeal workflows; incident roles; change approval; and vendor-exit plans. Signed receipts make decisions reviewable, but competent review bodies must exist and have authority. Open standards reduce lock-in only when contracts preserve data export, key control, documentation, and transition assistance.

Assurance should be evidence-based rather than brand-based. Recommended evidence includes policy unit and property

tests, deny-path tests, key-rotation drills, status-list freshness tests, simulated rights requests, transfer-register reconciliation, configuration-drift scans, restore exercises, accessibility and language tests, and independent penetration testing. Higher-risk proctoring and analytics additionally require necessity, proportionality, bias, and non-digital-alternative review.

VII. LIMITATIONS, VALIDITY THREATS, AND FUTURE WORK

A. Construct and Internal Validity

The analytical score depends on the declared comparator, objective definitions, and 0/0.5/1 rubric. It measures explicit control presence, not exploit resistance, operational maturity, or administrator behavior. Independent reviewers may assign different scores. The synthetic policy experiment uses a ground truth generated from the same conceptual predicates used to motivate the architecture, creating a favorable construct alignment. The comparison remains useful for exposing incremental expressiveness, but it cannot prove real-world superiority. Publishing row-level scores, per-seed metrics, and

TABLE XIII
THREE-PHASE IMPLEMENTATION AND ASSURANCE ROADMAP

Phase	Indicative horizon	Core engineering and governance work	Exit evidence
1. Institutional foundation	0–6 months	Inventory data/flows; classify resources; separate workload identities; deploy phishing-resistant access for privileged roles; centralize PDP/PEP; define purpose, retention, rights, incident, and key-management ownership.	Approved data-flow register; privileged-access test; deny-path suite; key-rotation drill; high-risk decision receipts; baseline accessibility and recovery test.
2. Governed federation	6–18 months	Establish partner and issuer trust registries; encode reviewed jurisdiction profiles; deploy transfer gateway; introduce minimized views and interoperable credentials; test status, revocation, partner exit, and cross-institution incident coordination.	Signed partner profiles; transfer-policy conformance tests; blocked-transfer evidence; credential interoperability test; revocation propagation; exit/migration rehearsal.
3. Privacy-enhanced analytics	18–36 months	Separate operational and analytical stores; introduce pseudonymization, cohort floors, budgets, secure aggregation or federated computation; publish learner explanations; evaluate benefit, bias, and model leakage.	Privacy-budget ledger; small-cohort denial; repeated-query test; utility and leakage report; learner-facing transparency review; independent security/privacy assessment.

generator code permits sensitivity analysis and replacement of the baseline.

The simulator’s latency is modeled rather than measured. It is retained to compare path complexity under a fixed distribution and is clearly separated from the single-host microbenchmark. The microbenchmark itself omits network, storage, parsing, distributed consistency, cold starts, hardware-security modules, mobile hardware, and multi-tenant contention. Timing values must not be transferred to production capacity planning without new measurement.

B. External, Legal, and Organizational Validity

No real country, institution, learner, regulator, or cloud deployment is evaluated. The legal discussion is purposive and illustrative; it does not enumerate every African law, sector rule, regulator decision, localization requirement, treaty update, or contractual regime. Every jurisdiction profile requires current review by competent institutional and legal personnel. The architecture is law-aware but not law-determining and does not certify a transfer.

The connectivity and governance indicators are aggregate contextual signals with different denominators and dates. They do not characterize every locality, institution, or learner. Organizational capability, procurement constraints, legacy integration, staffing, language, accessibility, and trust relationships may dominate technical feasibility. No human-subject study evaluates learner comprehension, consent quality, recovery burden, perceived surveillance, disability access, or institutional cost.

C. Privacy and Security Residual Risk

Zero trust reduces implicit trust but does not eliminate compromised endpoints, malicious insiders, supply-chain compromise, coerced users, fraudulent issuers, semantic policy mistakes, or insecure recovery. Verifiable credentials prove issuer-controlled statements and integrity; they do not prove educational quality or legal recognition. Differential privacy and federated analytics reduce selected disclosure risks but do not make models or repeated analyses risk-free. Offline acceptance necessarily creates bounded freshness risk.

D. Future Work

Future work should implement a standards-conformant prototype with a production policy engine, workload identity, hardware-backed keys, credential-wallet interoperability, proof-bound tokens, and a formal jurisdiction-profile schema. Multi-country pilots should test low-bandwidth synchronization, status under intermittent connectivity, rights workflows, incident coordination, regulator-facing evidence, and partner exit. Red-team exercises should include token replay, compromised issuer keys, malicious partner APIs, slow exfiltration, policy rollback, recovery abuse, registry poisoning, and analytics inference. Participatory research with learners, educators, registrars, disability advocates, privacy professionals, and regulators should determine whether the system delivers understandable agency rather than technical compliance alone.

VIII. ETHICS, DATA, AND REPRODUCIBILITY STATEMENT

The study uses only synthetic requests, synthetic cohort counts, abstract jurisdiction profiles, and local cryptographic test payloads. It contains no human-subject interaction, personal data, biometric sample, student record, production institution log, or named-country policy performance result. The companion artifact includes the complete $\LaTeX$ source, Bib $\TeX$ database, source CSV files, per-seed metrics, raw benchmark measurements, environment metadata, vector/raster figures, and scripts for regenerating the policy simulation, DP study, staleness study, microbenchmark, and figures. A public archival DOI or repository URL should be inserted only after the author deposits the final reviewed artifact.

The author declares that the architecture and experiments are research artifacts and do not constitute legal advice, accreditation evidence, vendor certification, or a guarantee of security. No external funding source or conflict of interest is declared in this article.

IX. CONCLUSION

This paper presents AFRICA-ZT-EDU, a policy-centric zero-trust and privacy-preserving reference architecture for cross-border digital education in Africa. Its central claim is architectural: protected-data decisions should bind subject, device, workload, resource, action, purpose, basis, jurisdiction,

minimization, risk, and accountability before a receiving service obtains learner data. Regional encrypted zones retain authoritative records; transfer gateways release short-lived claim views; W3C Verifiable Credentials support portable academic proof; privacy-enhanced analytics reduce unnecessary pooling; and signed receipts make decisions reviewable.

The design derives fourteen traceable requirements, reaches 34 of 36 analytical control objectives under a declared rubric, and is evaluated over 3,000,000 synthetic requests. Under those assumptions, it records a 0.0095% false-permit rate, blocks 99.750% of otherwise-authorized prohibited transfers, and reduces average disclosed fields by 61.26%. A separate local microbenchmark records 0.1210 ms median and 0.1384 ms p95 for the selected composite gate, while the DP experiment demonstrates an explicit privacy-utility trade-off. These results are encouraging but deliberately bounded. Deployment quality will depend on current legal review, policy-data quality, institutional governance, usable recovery, key management, low-connectivity engineering, accessibility, and independent security/privacy validation. The included artifact makes the assumptions, data, figures, and measurements inspectable so that subsequent studies can challenge the model and extend it through real pilots.

ARTIFACT AVAILABILITY

The Overleaf-ready companion package includes the complete article source, bibliography, fully bordered table design, vector and raster figures, contextual source data, row-level threat scores, 30-seed policy results, DP and staleness outputs, raw microbenchmark samples, environment metadata, and executable scripts. A public archival repository identifier should be added before journal submission.

REFERENCES

- [1] African Union Commission, “Digital education strategy and implementation plan 2023–2028,” African Union, Addis Ababa, Ethiopia, Tech. Rep., Nov. 2022, accessed: Aug. 18, 2026. [Online]. Available: <https://au.int/en/documents/20221125/digital-education-strategy-and-implementation-plan>
- [2] —, “AU Data Policy Framework,” African Union, Addis Ababa, Ethiopia, Tech. Rep., Jul. 2022, accessed: Aug. 18, 2026. [Online]. Available: <https://au.int/en/documents/20220728/au-data-policy-framework>
- [3] International Telecommunication Union, “Measuring digital development: Facts and figures 2025,” ITU, Geneva, Switzerland, Tech. Rep., 2025, indicator values cross-checked against ITU DataHub; accessed Aug. 18, 2026. [Online]. Available: <https://www.itu.int/itu-d/reports/statistics/facts-figures-2025/>
- [4] UN Trade and Development, “Global cyberlaw tracker: Data protection and privacy legislation worldwide,” 2026, accessed: Aug. 18, 2026. [Online]. Available: <https://unctad.org/page/data-protection-and-privacy-legislation-worldwide>
- [5] African Union, “African union convention on cyber security and personal data protection,” Jun. 2014, adopted Jun. 27, 2014; entered into force Jun. 8, 2023; accessed Aug. 18, 2026. [Online]. Available: <https://au.int/en/treaties/african-union-convention-cyber-security-and-personal-data-protection>
- [6] —, “Status list: African union convention on cyber security and personal data protection,” Jul. 2024, dated Jul. 8, 2024; historical snapshot used in this manuscript; accessed Aug. 18, 2026. [Online]. Available: https://au.int/sites/default/files/treaties/29560-sl-AFRICAN_UNION_CONVENTION_ON_CYBER_SECURITY_AND_PERSONAL_DATA_PROTECTION.pdf
- [7] S. W. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero trust architecture,” National Institute of Standards and Technology, Tech. Rep. NIST SP 800-207, 2020. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-207>
- [8] R. Chandramouli and Z. Butcher, “A zero trust architecture model for access control in cloud-native applications in multi-location environments,” National Institute of Standards and Technology, Tech. Rep. NIST SP 800-207A, 2023. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-207A>
- [9] K. Boeckl, N. Lefkowitz, E. Nadeau, D. Yaga, and M. Fagan, “NIST Privacy Framework: A Tool for Improving Privacy through Enterprise Risk Management, Version 1.0,” National Institute of Standards and Technology, Tech. Rep. NIST CSWP 10, 2020. [Online]. Available: <https://doi.org/10.6028/NIST.CSWP.01162020>
- [10] S. Brooks, M. Garcia, N. Lefkowitz, S. Lightman, and E. Nadeau, “An introduction to privacy engineering and risk management in federal systems,” National Institute of Standards and Technology, Tech. Rep. NISTIR 8062, 2017. [Online]. Available: <https://doi.org/10.6028/NIST.IR.8062>
- [11] T. Hoel and W. Chen, “Privacy and data protection in learning analytics should be motivated by an educational maxim—towards a proposal,” *Research and Practice in Technology Enhanced Learning*, vol. 13, no. 1, p. 20, 2018.
- [12] K. M. L. Jones, “Learning analytics and higher education: A proposed model for establishing informed consent mechanisms to promote student privacy and autonomy,” *International Journal of Educational Technology in Higher Education*, vol. 16, p. 24, 2019.
- [13] D. Ifenthaler and C. Schumacher, “Student perceptions of privacy principles for learning analytics,” *Educational Technology Research and Development*, vol. 64, no. 5, pp. 923–938, 2016.
- [14] T. Hoel, D. Griffiths, and W. Chen, “The influence of data protection and privacy frameworks on the design of learning analytics systems,” in *Proceedings of the 7th International Learning Analytics and Knowledge Conference*, 2017, pp. 243–252.
- [15] T. Hoel and W. Chen, “Privacy engineering for learning analytics in a global market: Defining a point of reference,” *International Journal of Information and Learning Technology*, vol. 36, no. 4, pp. 288–298, 2019.
- [16] D. Simic, N. B. Redep, S. Rako, N. Kadoic, W. V. Petegem, B. Rienties, N. C. Lanzo, M. Eichhorn, L. Guardia, S. K. Softic, and A. Tillmann, “HELA-CMM: Capability Maturity Model for Adoption of Learning Analytics in Higher Education,” *International Journal of Educational Technology in Higher Education*, vol. 22, p. 25, 2025.
- [17] K. Ahsan, S. Akbar, B. Kam, and M. D.-A. Abdulrahman, “Implementation of micro-credentials in higher education: A systematic literature review,” *Education and Information Technologies*, vol. 28, pp. 13 505–13 540, 2023.
- [18] S. Varadarajan, J. H. L. Koh, and B. K. Daniel, “A systematic review of the opportunities and challenges of micro-credentials for multiple stakeholders: Learners, employers, higher education institutions and government,” *International Journal of Educational Technology in Higher Education*, vol. 20, p. 13, 2023.
- [19] A. Rustemi, F. Dalipi, V. Atanasovski, and A. Risteski, “DIAR: A Blockchain-Based System for Generation and Verification of Academic Diplomas,” *Discover Applied Sciences*, vol. 6, no. 6, p. 297, 2024.
- [20] X. Wang, X. Xu, V. N.-L. Lei, and S. Hao, “Conceptual design of the blockchain-based student identity management system (BSIMS) model for higher education personal learning environments,” *Discover Computing*, vol. 28, no. 1, p. 42, 2025.
- [21] World Wide Web Consortium, “Verifiable credentials data model v2.0,” W3C Recommendation, May 2025, recommendation dated May 15, 2025; accessed Aug. 18, 2026. [Online]. Available: <https://www.w3.org/TR/vc-data-model-2.0/>
- [22] African Union Commission, “Guidelines for integrating data provisions in protocols on digital trade,” African Union, Addis Ababa, Ethiopia, Tech. Rep., May 2025, accessed: Aug. 18, 2026. [Online]. Available: <https://au.int/en/documents/20250522/guidelines-integrating-data-provisions-protocols-digital-trade>
- [23] Kingdom of Morocco, “Law no. 09-08 on the protection of individuals with regard to the processing of personal data,” 2009, official French title: Loi n. 09-08; accessed Aug. 18, 2026. [Online]. Available: <https://www.cndp.ma/loi-09-08/>
- [24] Commission Nationale de Contrôle de la Protection des Données à Caractère Personnel, “Transfert de données à l’étranger,” 2026, accessed: Aug. 18, 2026. [Online]. Available: <https://www.cndp.ma/transfert-de-donnees-a-letranger/>
- [25] Republic of Kenya, “Data protection act, no. 24 of 2019,” 2019, see Sections 48–50; accessed Aug. 18, 2026. [Online]. Available: https://kenyalaw.org/kl/fileadmin/pdfdownloads/Acts/2019/TheDataProtectionAct_No24of2019.pdf

- [26] —, “Data protection (general) regulations, 2021,” 2021, accessed: Aug. 18, 2026. [Online]. Available: <https://www.odpc.go.ke/wp-content/uploads/2022/04/Data-Protection-General-Regulations-2021.pdf>
- [27] Republic of South Africa, “Protection of personal information act 4 of 2013,” 2013, see Section 72; accessed Aug. 18, 2026. [Online]. Available: <https://www.gov.za/documents/protection-personal-information-act>
- [28] European Parliament and Council of the European Union, “Regulation (EU) 2016/679 (general data protection regulation),” 2016, see Arts. 25 and 44; accessed Aug. 18, 2026. [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- [29] M. Deng, K. Wuyts, R. Scandariato, B. Preneel, and W. Joosen, “A privacy threat analysis framework: Supporting the elicitation and fulfillment of privacy requirements,” *Requirements Engineering*, vol. 16, no. 1, pp. 3–32, 2011.
- [30] A. Shostack, *Threat Modeling: Designing for Security*. Indianapolis, IN, USA: Wiley, 2014.
- [31] J. H. M. Emati, V. K. Tchendji, and M. Djam-Doudou, “A zero-trust decentralized identifier specification based machine learning against cyber-attacks in blockchain-based self-sovereign identity,” *Journal of Cloud Computing*, vol. 15, no. 1, p. 27, 2026.
- [32] World Wide Web Consortium, “Bitstring status list v1.0,” W3C Recommendation, May 2025, recommendation dated May 15, 2025; accessed Aug. 18, 2026. [Online]. Available: <https://www.w3.org/TR/vc-bitstring-status-list/>
- [33] National Institute of Standards and Technology, “Implementing a zero trust architecture,” National Institute of Standards and Technology, National Cybersecurity Center of Excellence, Tech. Rep. NIST SP 1800-35, Jun. 2025, final publication; accessed Aug. 18, 2026. [Online]. Available: <https://csrc.nist.gov/pubs/sp/1800/35/final>
- [34] D. Temoshok, D. Proud-Madruga, Y.-Y. Choong, R. Galluzzo, S. Gupta, C. LaSalle, N. Lefkovitz, and A. Regenscheid, “Digital identity guidelines,” National Institute of Standards and Technology, Gaithersburg, MD, USA, Tech. Rep. NIST SP 800-63-4, Jul. 2025. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-63-4>
- [35] W3C Web Authentication Working Group, “Web authentication: An API for accessing public key credentials – level 3,” World Wide Web Consortium, W3C Candidate Recommendation Snapshot, May 2026, snapshot dated May 26, 2026; not a final W3C Recommendation; accessed Aug. 18, 2026. [Online]. Available: <https://www.w3.org/TR/webauthn-3/>
- [36] V. C. Hu, D. Ferraiolo, R. Kuhn, A. Schnitzer, K. Sandlin, R. Miller, and K. Scarfone, “Guide to attribute based access control (ABAC) definition and considerations,” National Institute of Standards and Technology, Gaithersburg, MD, USA, Tech. Rep. NIST SP 800-162, 2019, updated edition. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-162>
- [37] R. Chandramouli, “Attribute-based access control for microservices-based applications using a service mesh,” National Institute of Standards and Technology, Tech. Rep. NIST SP 800-204B, 2021. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-204B>
- [38] H. B. McMahan, E. Moore, D. Ramage, S. Hampson, and B. A. y Arcas, “Communication-efficient learning of deep networks from decentralized data,” in *Proceedings of the 20th International Conference on Artificial Intelligence and Statistics (AISTATS)*, ser. Proceedings of Machine Learning Research, vol. 54, 2017, pp. 1273–1282. [Online]. Available: <https://proceedings.mlr.press/v54/mcmahan17a.html>
- [39] K. Bonawitz, V. Ivanov, B. Kreuter, A. Marcedone, H. B. McMahan, S. Patel, D. Ramage, A. Segal, and K. Seth, “Practical secure aggregation for privacy-preserving machine learning,” in *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security*, 2017, pp. 1175–1191.
- [40] C. Dwork, “Differential privacy,” in *Automata, Languages and Programming (ICALP)*, ser. Lecture Notes in Computer Science, vol. 4052, 2006, pp. 1–12.
- [41] S. Gabrielli, S. Krenn, D. Pellegrino, J. C. P. Baúñ, P. P. Berganza, S. Ramacher, and W. Vandeveld, “KRAKEN: A Secure, Trusted, Regulatory-Compliant, and Privacy-Preserving Data Sharing Platform,” in *Data Spaces: Design, Deployments and Future Directions*. Springer, 2022, pp. 107–130.
- [42] African Union, “Protocol to the agreement establishing the african continental free trade area on digital trade,” Treaty text, Feb. 2024, adopted Feb. 18, 2024; accessed Aug. 18, 2026. [Online]. Available: <https://au.int/en/treaties/protocol-agreement-establishing-african-continental-free-trade-area-digital-trade>
- [43] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, “A design science research methodology for information systems research,” *Journal of Management Information Systems*, vol. 24, no. 3, pp. 45–77, 2007.
- [44] B. Campbell, J. Bradley, N. Sakimura, and T. Lodderstedt, “OAuth 2.0 Mutual-TLS Client Authentication and Certificate-Bound Access Tokens,” RFC 8705, Feb. 2020. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc8705>
- [45] D. Fett, B. Campbell, J. Bradley, T. Lodderstedt, M. Jones, and D. Waite, “OAuth 2.0 Demonstrating Proof of Possession (DPoP),” RFC 9449, Sep. 2023. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc9449>